Mo Tu We Th Fr Sa Su

Meme No. IMP sec& RA

Date / /

# ISO 27001 : 2022

* Based on the ISMS series, 27000 is vocab, 27001 is Requirment 27002 is guide & the rest have its own purposes.

* By using PDCA we have Plan (4-7), Do (8), Check (9) & Act (10) due to having 10 clauses. As clause 0-3 are introducforg.

## II. Clause 4: Context of the organization

understand the enviroment in which operate.

- 4.1: determine external & interal issues that affect the ISMS outcome.

4.2. Identify interested party and their requirements including legal, regulatory and contractual one.

4.3. Define ISMS scope (boundaries and applicabilities) & keep information documented.

4.4. Establish implementation, maintain & continually improve the ISMS

## II. clause 5: Leadership

Top manager must drive the ISMS

5.1. show commitment: set policy, obejective, process & resource to improve.

Mo Tu We Th Fr Sa Su

Meme No.
Date / /

5.2. Establish a documented IS policy, internal communication & available to interested parties.

5.3. Assign roles, responsibility & authorities.

## VI. Clause 6: planning

6.1.1. Identify risk & opportunities to address

6.1.2. Risk assessment; define risk criteria & acceptance levels, identify risk CIA, risk owners, analyze and evaluate risk and keep info documented.

6.1.3. Risk treatment: treat with control → produce SOA → create Risk treatment plans, obtain risk owner approval & acceptance of residual risk.

6.2. set measurable, monitored & documented security objective, plan what, who, when, resources & evaluations.

6.3. carry out ISMS ~~plan~~ changes in planned manners.

## VII. clause 7: support.

7.1. Resource as ISMS needed

7.2. competense ensure delegation and keep as evidence

7.3. Awareness of policy implemented & unsun consequences of ignorant.

Mo Tu We Th Fr Sa Su

Meme No.
Date / /

7.4. Communication to know what, when & whom to contact

7.5. Documented informations (identification, format, approval, access, version control, retention & protection)

## VIII clause 8: Operation

8.1. implement as planned & needed both outsource process.

8.2. perform RA when there changes & retain result ~~intervally~~.

8.3. Implement risk treatment plan and retain result.

## IX. clause 9: Performance Evaluation

9.1. Monitor, measure and analyze the implemented ISMs effectiveness.

9.2. have internal audit to report result to manager.

9.3. Top manage reviews the ISMS intervals to see previous actions, changes in context, performance trend, risk status or improvement opportunities to output on decision changes.

## X. clause 10: Improvement.

10.1. Continue improvement, suitabilities, adequacy & effectiveness.

10.2. when sth wrong, find the root and do corrective action both update ISMS as needed as records.

Mo Tu We Th Fr Sa Su

Meme No.
Date / /

## Annex A: Information Security controls Reference

Annex A contains 93 controls in 4 categories (derived from ISO/IEC 27002:2022 and must be compared against the organization owns controls when producing a SoA (6.23). controls can be excluded WT the justification.

### A.5. organizational

Consist of 37 controls ranged from 5.1-5.37 include:

> policy, roles, segregation of duties, asset management, access control, supplier, relationships, cloude services, Incident management, business continuity, legal and privacy compliance.

### A.6. People

Consists of 8 controls ranged from 6.1-6.8 include:

> Screening, employement terms, awareness & training, disciplinary process, NDAs remote working & event reporting.

### A.7. Physical

consts of 14 controls ranged from 7.1-7.14 include:

> security perimeters, entry controls, clear desk, and screen, equipment protection. cabling, storage, medra & secure disposal

### A.8. Technology

Consists of 34 controls ranged from 8.1-8.34 include:

> Endpoint devices, privilege access, authentication, malware protection, vuln management, backup, logging, monitoring, network security, cryptography secure development, change management and audit testing.